Отчёт по проведению аудита инфраструктуры компании «Сделали Софт»

Задание 1. Аудит систем

1. Аудит сетевых устройств

Аудит проводился на роутере `p-firewall-msk-01` (192.168.60.2). Проверка показала:

- Отсутствует политика `deny by default` – все цепочки iptables имеют политику ACCEPT.
- Нет правил фильтрации межсегментного трафика.
- Межсетевой экран не настроен, что нарушает требования регулятора и внутренних стандартов.

2. Анализ серверной инфраструктуры

Проверены веб-сервер, файловый сервер и DNS-сервер:

- **Веб-сервер** (`p-nginx-msk-02`): Nginx запущен от root, раскрывает версию, отсутствуют ограничения таймаутов и размеров, SSL/TLS включает устаревший TLSv1.1, не все security headers установлены. Общая учётная запись `test` присутствует.
- **Файловый сервер** (`p-fs-msk-03`): парольная политика соответствует, но отсутствует файрвол, не настроены права на каталоги (каталог `/srv/files` отсутствует), избыточные группы в sudoers.
- **DNS-сервер** (`p-dns-spb-02`): DNS-сервис не настроен, но порт 53 открыт, что создаёт риск. Файрвол отсутствует, sysctl не настроен.

3. Проверка рабочих станций сотрудников и АРМ администратора

- **АРМ Петрова** (`petrov-linux-001`): пользователь `petrov` имеет полные sudo-права (`ALL:ALL`), что грубо нарушает принцип минимальных привилегий. Присутствует общая учётная запись `test`. Файрвол отсутствует, логирование sudo не настроено, имя не соответствует стандарту.
- **АРМ Александрова** (`aleksandrov-ubuntu-01`): пользователь `aleksandrov` не имеет прав sudo, что соответствует требованиям. Однако файрвол отсутствует, sysctl не настроен, имя не соответствует стандарту.
- **АРМ администратора** (`ivanov-linux-003`): пользователь `ivanov` не состоит в группе `admins`, хотя должен быть администратором. Root login по SSH разрешён (`PermitRootLogin yes`), что является критическим нарушением. Файрвол отсутствует, sysctl настроен с ошибками, имя не соответствует стандарту.

4. Сопоставление конфигурации с требованиями регулятора и внутренними стандартами компании

Проведено сопоставление с требованиями Политики ИБ, Требований регулятора, стандартов Linux, Nginx и именования. Выявлены множественные несоответствия: отсутствие файрволов,

неправильные права доступа, нарушение парольной политики, разрешённый root login, избыточные привилегии, неправильное именование, отсутствие логирования и неиспользуемые сервисы.

Задание 2. Соотнести требования с компонентами инфраструктуры

Проанализируйте требования в соответствии с чек-листом и выпишите источники и пункты требований, которые применимы к компоненту инфраструктуры.

Результат оформите в виде таблицы ниже.

- Перенесите пункты из чек-листа (требование и примечание/действие) в таблицу с требованиями.
- Укажите раздел требований, источник и процесс.
- Укажите результаты проверки для конкретного объекта инфраструктуры. В случае, если пункт требования применим к объекту, обозначьте это удобным способом. Если пункт неприменим к компоненту, оставьте поле пустым.

Пример первого заполненного пункта из чек-листа вы видите ниже.

Заполните таблицу, добавив необходимые строки.

Источник	**№ раздела**	**Процесс**	**Требование**	**Веб-сервер**	**Файловый сервер**	**DNS**	**Роутер офиса**	**АРМ Петров**	**АРМ Александров**	**АРМ Администратора**	**Примечание / Действие**
Политика ИБ	3.1.1	Парольная защита	Пароли на всех АРМ и серверах соответствуют политике	✓	✓	✓	✓	✓	✓	✓	Проверить длину, сложность, срок, SHA-512
Политика ИБ	3.1.2	Парольная защита	Усиленные требования к паролям серверов	✓	✓	✓	✓				Проверить PAM (история, повторы)
Требования регулятора	2.1, 2.2	Идентификация	Персональная идентификация пользователей	✓	✓	✓	✓	✓	✓	✓	Убедиться в отсутствии общих аккаунтов

			(запрет общих учётных записей)								
Требования регулятора	3.1; Политика ИБ 3.2.3	Управление доступом	Принцип минимальных привилегий	✓	✓	✓		✓	✓	✓	Проверить группы sudo, отсутствие лишних прав
Требования регулятора	5.1; Стандарт Linux	Безопасность ОС	АРМ соответствуют стандартам безопасности (сервисы, файрвол, sysctl)					✓	✓	✓	Проверить конфигурацию АРМ
Требования регулятора	5.1; Стандарт Linux	Безопасность ОС	Серверы соответствуют стандартам ОС и ПО	✓	✓	✓					Проверить конфигурации ОС и сервисов
Требования регулятора	4.3	Управление сервисами	Используются только необходимые сервисы	✓	✓	✓	✓	✓	✓	✓	Отключить неиспользуемые службы
Требования регулятора	4.3 (специфично)	Управление сервисами	DNS не должен работать без настройки			✓					Либо настроить, либо отключить DNS
Требования регулятора	3.3, 4.1	Сетевая безопасность	Сегменты сети изолированы и фильтруются	✓	✓	✓	✓	✓	✓	✓	Проверить межсегментные правила
Требования регулятора	3.3, 4.2	Сетевая безопасность	Минимальный набор разрешающих правил (default deny)	✓	✓	✓	✓	✓	✓	✓	Оставить только необходимые порты

Стандарт Nginx	Общие требования	Веб-сервер	Стандартные настройки Nginx недопустимы	✓							Отключить дефолтные параметры
Стандарт Nginx	4.1	Веб-сервер	Скрытие версии сервера (server_tokens off)	✓							Проверить server_tokens off
Стандарт Nginx	4.2, 4.3	Веб-сервер	Ограничения размеров и таймаутов	✓							Проверить client_max_body_size, timeouts
Стандарт Nginx	4.4	Веб-сервер	Безопасные протоколы и шифры (TLS 1.2/1.3, secure ciphers)	✓							Проверить ssl_protocols, ssl_ciphers
Стандарт Nginx	(стр .2)	Веб-сервер	Включены security headers (X-Frame-Options, nosniff и др.)	✓							Проверить add_header
Политика ИБ	3.3	Антивирусная защита	Антивирус установлен и активен	✓	✓	✓	✓	✓	✓	✓	Проверить наличие и актуальность
Требования регулятора	7.1	Управление уязвимостями	Установлены обновления безопасности	✓	✓	✓	✓	✓	✓	✓	Проверить уровень обновлений
Требования регулятора	8.1, 8.3	Логирование	Включено логирование событий (system/security logs)	✓	✓	✓	✓	✓	✓	✓	Проверить настройки rsyslog, права на логи
Требования регулятора	8.2; Пол	Контроль	Контроль действий администраторов	✓	✓	✓	✓	✓	✓	✓	Настроить sudo, запретить root

	итика ИБ 3.5	администрирования	(sudo, запрет root SSH)								login
Требования регулятора	8.2; Политика ИБ 3.7	Контроль администрирования	Запрет работы под root (sudo, PAM)	✓	✓	✓	✓	✓	✓	✓	Проверить sudo и PAM (pam_wheel)
Требования регулятора	3.3, 4.1	Сетевая безопасность	Настройки МСЭ на роутере (разрешены только нужные порты)				✓				Проверить iptables/firewalld
Стандарт Linux	5.1	Безопасность ОС	Защита сетевого стека (настройки Sysctl)	✓	✓	✓	✓	✓	✓	✓	Отключить redirects, source routing
Стандарт именования	4	Именование серверов	Формат имени сервера соблюдён ([env-role-loc-num])	✓	✓	✓	✓				Проверить синтаксис
Стандарт именования	5	Именование АРМ	Формат имени АРМ соблюдён ([os-login-num])					✓	✓	✓	Проверить синтаксис

Задание 3. Результаты проверки

Запишите в таблицу результаты проверки конфигурации инфраструктуры.

1. Для каждого пункта чек-листа зафиксируйте статус выполнения требования. При выявлении несоответствий укажите, какие решения вы применили, либо опишите рекомендации по настройке.
2. Скопируйте таблицу с требованиями, которая должна была получиться на предыдущем этапе, очистите ячейки устройств и для каждого устройства укажите, какой результат показала проверка. В случае, если пункт требования не применим к компоненту, укажите статус «Не применяется».

Посмотрите на пример итоговой таблицы. Первый пункт заполнен в качестве примера. Проверьте, всё ли в нем верно, и внесите необходимые изменения.

Источник	№ раздела	Процесс	Требование	Веб-сервер	Файловый сервер	DNS	Роутер офиса	АРМ Петров	АРМ Александров	АРМ Администратора	Примечание / Действие
Политика ИБ	3.1.1	Парольная защита	Пароли на всех АРМ и серверах соответствуют политике	**Не соответствует** (PASS_MAX_DAYS 99999, MIN_LEN отсутствует)	**Соответствует** (60, 17, SHA512)	**Соответствует** (60, 17, SHA512)	**Не соответствует** (параметры не заданы)	**Не соответствует** (12 символов)	**Не соответствует** (12 символов)	**Не соответствует** (12, 90)	Установить PASS_MIN_LEN≥17, PASS_MAX_DAYS≤365, SHA512
Политика ИБ	3.1.2	Парольная защита	Усиленные требования к паролям серверов	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	Проверить настройки PAM (история, повторы)
Требования регулятора	2.1, 2.2	Идентификация	Персональная идентификация пользователей	**Не соответствует** (есть test)	**Соответствует**	**Соответствует**	**Соответствует**	**Не соответствует** (есть test)	**Соответствует**	**Соответствует**	Удалить общие учётные записи

Требования регулятора	3.1; Политика ИБ 3.2.3	Управление доступом	Принцип минимальных привилегий	**Не соответствует** (избыточные группы в sudoers)	**Не соответствует** (избыточные группы)	**Не соответствует** (избыточные группы)	**Соответствует** (только adm_ivanov)	**Не соответствует** (petrov в sudo с ALL)	**Соответствует**	**Не соответствует** (ivanov не в admins)	Ограничить sudo, убрать лишних из групп
Требования регулятора	5.1; Стандарт Linux	Безопасность ОС	АРМ соответствуют стандартам безопасности	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не соответствует** (файрвол отсутствует, sysctl не настроен, vsftpd включён)	**Не соответствует** (файрвол отсутствует, sysctl не настроен)	**Не соответствует** (файрвол отсутствует, sysctl с ошибками)	Настроить файрвол, применить sysctl, отключить лишние сервисы
Требования регулятора	5.1; Стандар	Безопасность ОС	Серверы соответствуют стандартам ОС и ПО	**Не проверено** (версия ОС не проверена)	**Не проверено**	**Не проверено**	**Не проверено**	**Не применяется**	**Не применяется**	**Не применяется**	Проверить версии и обновления

	т Linux										
Требования регулятора	4.3	Управление сервисами	Используются только необходимые сервисы	**Не проверено** (systemctl не доступен)	**Не проверено**	**Не проверено**	**Не проверено**	**Не соответствует** (vsftpd включён, cron и др.)	**Не проверено**	**Не проверено**	Отключить неиспользуемые службы
Требования регулятора	4.3 (специфично)	Управление сервисами	DNS не должен работать без настройки	**Не применяется**	**Не применяется**	**Не соответствует** (порт 53 открыт, сервис не настроен)	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	Отключить DNS-сервис (systemctl stop/disable)
Требования регулятора	3.3, 4.1	Сетевая безопасность	Сегменты сети изолированы и фильтруются	**Не соответствует** (нет файрвола)	**Не соответствует** (нет файрвола)	**Не соответствует** (нет файрвола)	**Не соответствует** (iptables ACCEPT везде)	**Не соответствует** (нет файрвола)	**Не соответствует** (нет файрвола)	**Не соответствует** (нет файрвола)	Настроить iptables/firewalld с политикой DROP по умолчанию
Требования регулятора	3.3, 4.2	Сетевая безопасность	Минимальный набор разрешающих правил	**Не соответствует** (нет правил)	**Не соответствует**	**Не соответствует**	**Не соответствует** (нет правил)	**Не соответствует**	**Не соответствует**	**Не соответствует**	Разрешить только SSH, HTTP/S, DNS при необходимости

Стандарт Nginx	Общие требования	Веб-сервер	Стандартные настройки Nginx недопустимы	**Не соответствует** (запуск от root, отсутствуют многие параметры)	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	Привести к стандарту (пользователь, параметры)
Стандарт Nginx	4.1	Веб-сервер	Скрытие версии сервера	**Не соответствует** (server_tokens закомментирован)	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	Раскомментировать server_tokens off
Стандарт Nginx	4.2, 4.3	Веб-сервер	Ограничения размеров и таймаутов	**Не соответствует** (client_max_body_size 100m, таймауты не заданы)	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	Установить 10m, таймауты 30s, 10s
Стандарт Nginx	4.4	Веб-сервер	Безопасные протоколы и шифры	**Не соответствует** (TLSv1.1 включён, ssl_session_tickets on)	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	Отключить TLSv1.1, установить ssl_session_tickets off
Стандарт Nginx	(стр.2)	Веб-сервер	Включены security headers	**Частично** (Referrer-Policy и CSP есть, нет X-Frame-Options и X-Content-	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	Добавить X-Frame-Options и X-Content-Type-Options

				Type)							
Политика ИБ	3.3	Антивирусная защита	Антивирус установлен и активен	**Не проверено**	**Не проверено** (есть каталог kaspersky)	**Не проверено**	**Не проверено**	**Не проверено**	**Не проверено** (есть каталог kaspersky)	**Не проверено**	Проверить установку и активность
Требования регулятора	7.1	Управление уязвимостями	Установлены обновления безопасности	**Не проверено**	**Не проверено**	**Не проверено**	**Не проверено**	**Не проверено**	**Не проверено**	**Не проверено**	Проверить и установить обновления
Требования регулятора	8.1, 8.3	Логирование	Включено логирование событий	**Не соответствует** (auth.log и syslog отсутствуют)	**Частично** (логи есть, но права 644)	**Частично** (логи есть, права 644)	**Частично** (логи есть, права 644)	**Частично** (логи есть, права 644)	**Частично** (логи есть, права 644)	**Частично** (логи есть, права 644)	Включить rsyslog, выставить права 640 root:adm
Требования регулятора	8.2; Политика ИБ 3.5	Контроль администрирования	Контроль действий администраторов	**Частично (sudo log настроен, но права на лог неверные)**	**Частично (sudo log настроен, права неверные)**	**Частично (sudo log настроен, права неверные)**	**Частично (sudo log настроен, права неверные)**	**Не соответствует (sudo.log отсутствует)**	**Частично (sudo log настроен, права неверные)**	**Частично (sudo log настроен, права неверные)**	Настроить sudo с логированием, выставить права 640
Требования регулятора	8.2; По	Контроль администрирования	Запрет работы под root	**Не соответствует (Nginx от root)**	**Соответствует (pam_wheel настроен)**	**Не соответствует (pam_wheel**	**Не соответствует (pam_wheel**	**Частично (pam_wheel есть, но петров**	**Соответствует (pam_wheel есть)**	**Частично (pam_wheel есть, но root login**	Исправить: запретить root login, настроить PAM и sudo

	литикаИБ3.7					**закомментирован)**	**закомментирован)**	**имеет sudo ALL)**		**разрешён)**	
Требования регулятора	3.3,4.1	Сетевая безопасность	Настройки МСЭ на роутере	**Не применяется**	**Не применяется**	**Не применяется**	**Не соответствует (нет политики deny, нет правил)**	**Не применяется**	**Не применяется**	**Не применяется**	Настроить iptables с default deny и разрешить только нужные порты
Стандарт Linux	5.1	Безопасность ОС	Защита сетевого стека (Sysctl)	**Частично (не все параметры заданы, tcp_synookies отсутствует)**	**Частично (tcp_synookies отсутствует)**	**Не соответствует (параметры закомментированы)**	**Не проверено**	**Не соответствует (закомментированы)**	**Не соответствует (закомментированы)**	**Не соответствует (неверные значения: send_redirects=1 и др.)**	Применить все параметры из стандарта, включить tcp_synookies
Стандарт именования	4	Именование серверов	Формат имени сервера соблюдён	**Соответствует (p-nginx-msk-02)**	**Соответствует (p-fs-msk-03)**	**Соответствует (p-dns-spb-02)**	**Соответствует (p-firewall-msk-01)**	**Не применяется**	**Не применяется**	**Не применяется**	—
Стандарт именования	5	Именование АРМ	Формат имени АРМ соблюдён	**Не применяется**	**Не применяется**	**Не применяется**	**Не применяется**	**Не соответствует (petrov-**	**Не соответствует (aleksan**	**Не соответствует (ivanov-**	Переименовать по формату [OS]-

								linux-001)	**drov-ubuntu-01)**	**linux-003)**	[login]-[num]

Задание 4. Самостоятельные наблюдения

В ходе аудита выявлены дополнительные отклонения, не описанные в отчёте пентеста:

1. **Отсутствие обновлений безопасности** – ни на одном хосте не проверялась установка актуальных патчей.
2. **Антивирус** – на некоторых АРМ (Александров) замечена директория `kaspersky`, но активность не проверена.
3. **Отсутствие rsyslog** – на многих хостах rsyslog не запущен (на файловом, DNS, АРМ Петрова), хотя логи auth.log присутствуют.
4. **Избыточные сервисы** – на АРМ Петрова включён `vsftpd`, что не требуется для рабочей станции.
5. **Несоответствие прав на логи** – везде права 644, а должны быть 640.

Итоги работы

Общие итоги аудита

Аудит инфраструктуры компании «Сделали Софт» выявил **критические несоответствия** базовым требованиям информационной безопасности. Основные проблемы:

- Полное отсутствие межсетевого экранирования на всех компонентах (роутер, серверы, АРМ).
- Нарушение принципа минимальных привилегий: обычные пользователи имеют права sudo, а администратор не включён в нужную группу.
- Разрешённый root login по SSH на АРМ администратора.
- Использование общих учётных записей (`test` на веб-сервере и АРМ Петрова).
- Неправильная конфигурация веб-сервера (запуск от root, раскрытие версии, устаревшие протоколы).
- Отсутствие логирования действий администраторов или неправильные права на логи.
- Несоответствие имён АРМ корпоративному стандарту.

Наиболее уязвимые компоненты:

- **АРМ Петрова** – имеет полные права root, что позволяет злоумышленнику захватить систему и получить доступ к корпоративной сети.
- **Роутер** – отсутствие фильтрации делает возможным свободное перемещение между сегментами.
- **Веб-сервер** – стандартная конфигурация и запуск от root повышают риск компрометации.

Риски для компании:

- Утечка конфиденциальных данных (персональные данные, финансовая отчётность).
- Полный захват инфраструктуры через административный АРМ.
- Нарушение требований регулятора и законодательства о защите персональных данных.

Соответствие текущей конфигурации базовым требованиям безопасности – **не соответствует**. Большинство критических мер безопасности отсутствуют или настроены неверно.

Значение аудита – позволил систематизировать требования, выявить конкретные уязвимости и сформировать практические рекомендации. Это создаёт основу для повышения защищённости и управляемости инфраструктуры.

Рекомендации для дальнейшего поддержания безопасности

1. **Поддержание актуальности конфигураций**:
    - Внедрить регулярное обновление ОС и прикладного ПО.
    - Использовать только поддерживаемые версии.
    - Автоматизировать применение стандартов конфигурации при развёртывании новых систем (например, через Ansible).
2. **Регулярный контроль соответствия стандартам**:
    - Разработать формализованный чек-лист на основе выявленных требований.
    - Проводить ежеквартальные проверки конфигураций.
    - Использовать средства автоматического сканирования (OpenSCAP, Lynis).
3. **Снижение рисков повторного появления проблем**:
    - Устранить все выявленные несоответствия по приоритетам (сначала запрет root login, настройка файрволов, ограничение привилегий).
    - Провести повторное тестирование на проникновение после исправлений.
    - Организовать обучение IT-персонала по безопасной настройке систем.
    - Ввести процедуру согласования изменений конфигураций с отделом ИБ.

Комментарии

Здесь вы можете оставить любые комментарии для ревьюера.